Open-source software Steward

October 22, 2026

OpenChain Japan Community Day vol.36
(OpenChain Japan & OpenSSF Collaboration Event)

OpenSSF Japan Working Group

池田　宗広（サイバートラスト）



Copyright © 2026 The Linux Foundation®. All rights reserved. The Linux Foundation has registered trademarks and uses trademarks.
This slide is licensed under the Creative Commons Zero 1.0 Universal

自己紹介



サイバートラスト株式会社
池田 宗広

LinkedIn

- 経歴
  - ✔ 4/8bitマイコン向け組込みSWエンジニア（アセンブリ言語）
  - ✔ 16bitマイコン向け組込みSWエンジニア（C言語）
  - ✔ 組込みセキュリティエンジニア
  - ✔ PSIRT(Product Security Incident Response Team)
  - ✔ 社内OSSコミュニティ活動推進
- Linux Foundation community
  - ✔ Open SSF Japan chapter
  - ✔ OpenChain Japan WG

Disclaimer

スピーカーは法律の専門家ではありません。

ここではスピーカーが CRA（EU Cyber Resilience Act）をウォッチし調べたことを共有しますが、誤りを含む可能性があります。

法令の正確・正式な意味・解釈は、別途専門家に確認を取ることをお勧めいたします。

Agenda

- Open-source softwareとOpen-source software Stewardの定義
- Open-source software Steward導入の目的
- Open-source software Stewardの義務
- Open-source software StewardのCRA対応ガイド

Open-source softwareと Open-source software Stewardの定義

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Open-source softwareの定義

- **フリー・オープンソースソフトウェア (free and open-source software)**
  ソースコードがオープンに共有され自由にアクセスし、使用し、改変し、再配布できるようにするすべての権利を提供するフリー・オープンソースライセンスの下で利用可能にされたソフトウェア（ Article3(48)）

  マニュファクチャラーが商業活動の一環として収益化し提供される場合のみ、 CRA の適用対象となる
  非営利団体による開発は、収益が非営利目的に使用される場合、商業活動とみなされない（前文 (18)）

この条項は、オープンソース プロジェクトやコミュニティへの貢献が CRA の対象外であることを明確にし、既存のオープンソース プロジェクトへの貢献に対する障壁を生じさせないことを保証

Open-source software stewardの定義

- **オープンソース・ソフトウェア・スチュワード (open-source software steward)**
  マニュファクチャラー以外の法人でフリーかつオープンソースソフトウェアとして適格であり、商業活動を目的としたデジタル要素を含む特定の製品の開発に対して、体系的な支援を継続的に提供する目的または目標を持ち、それらの製品の実行可能性を保証するもの（ Article3(14)）

CRAではマニュファクチャラーとオープンソース ソフトウェア スチュワードの役割を明確に区別しており、マニュファクチャラーはEU市場でデジタル要素を含む製品を商業的に提供する責任がある主体で、オープンソース ソフトウェア スチュワードはオープンソース製品の開発を体系的に支援し、その実行可能性を確保する組織
この定義は単なる個人開発者や非営利的な貢献者ではなく、 OSSの品質とセキュリティを保証する役割を担う組織的存在を対象としている

無料で提供されるソフトウェアのサイバーセキュリティ機能に対して、スチュワードが責任を負うことは困難であり、
CRA はこの課題を認識し、特定の商業製品におけるオープンソース コンポーネントの目的適合性について適切なデューデリジェンス評価を行う責任を、その製品のマニュファクチャラーに課している

Open-source software Steward導入の目的

Open-source software steward導入の目的

CRAが要求しているサイバーセキュリティ対策を全てのオープンソースソフトウェア開発に課すとオープンソースプロジェクトやコミュニティの成長を阻害する障壁となってしまうため、
CRAではオープンソースソフトウェアスチュワードという新しい概念を導入し、非営利のオープンソースソフトウェア開発への影響を最小限にしつつ、オープンソースソフトウェア開発者やコミュニティと利用者（デジタル要素を含む製品のマニュファクチャラー）間との責任分担の明確化と連携強化を図っている。

＜CRA義務の有無＞

区分	CRAの義務	備考
一般のOSS開発者	❌ 基本的に無し	非営利・個人開発者など
OSSスチュワード	✅ 該当する可能性あり	商用支援・配布・管理を行う場合
商用製品の製造者（OSSを含む）	✅ 義務あり	OSSを含む製品をEUで販売する場合

※参考：オープンソースにおけるサイバーセキュリティベストプラクティスへの道（Linux Foudation）

Open-source software Steward の義務

Open-source software Stewardの義務(第24条)

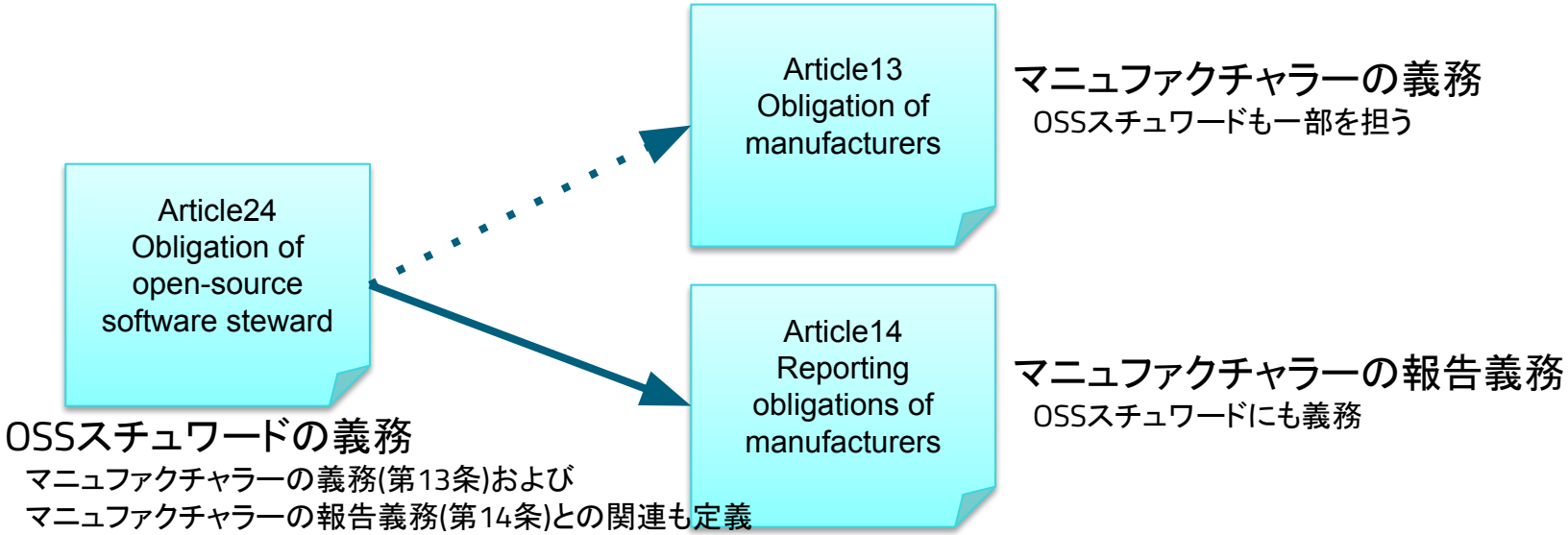
- デジタル要素を含む安全な製品の開発およびその製品の開発者による脆弱性の効果的な取り扱いを促進するために、サイバーセキュリティポリシーを策定し検証可能な方法で文書化しなければならない
  ポリシーには脆弱性の文書化、対処および修正に関する内容を含めなければならない（第1項）

- 市場監視当局（MSA）の要請に応じサイバーセキュリティリスクの軽減を支援しなければならない
  MSAから合理的な要請があった場合には、セイバーセキュリティポリシーを MSAが容易に理解できる言語で紙または電子形式でMSAに提供しなければならない（第2項）

- .第14条第1項の義務は、デジタル要素を含む製品の開発に関与している範囲で適用される
  第14条第3項、第8項の義務は、セキュリティに影響を与える重大なインシデントが、オープンソースソフトウェアの管理者が提供するネットワークおよび情報システムに影響を与える範囲で適用される（第 3項）

この条文では、商業的文脈で提供される OSSに関与するスチュワードに対して、セキュリティ確保のための具体的な責任が明記されている

Open-source software Stewardの義務と第13条、第14条



第24条ではOSSスチュワードの義務が定められており、第 24条に従い第13条および第14条のマニュファクチャラーの義務の一部もOSSスチュワードの義務と扱われる

CRA 第13条 マニュファクチャラーの義務

※赤字：OSSスチュワードの義務に関連がある条文

1. デジタル製品を市場に出す際、附属書Iの1「セキュリティ特性要件」を遵守して設計・開発・製造 されていることを確認する。
2. サイバーセキュリティ上のリスクアセスメントを実施し、その結果を設計・開発・製造・配送・メンテナ ンスの際の考慮に□れる。
3. デジタル製品を市場に出す際、上記のリスクアセスメントの結果を技術□書に含める。
4. 第31条および付属書VIIに従って要求される技術文書には、本条第3項で言及されるサイバーセキュリティリスク評価を含める。
5. **第三者から提供された部品を使 □する際は、その部品により製品のセキュリティリスクを □めないことを保証する。**
6. **特定した脆弱性を報告・対処・修復する。対処のための変更は機械可読形式でコンポーネントの製造または保守を行う個人または団体と共有する。**
7. デジタル製品に関するサイバーセキュリティ観点の情報を体系的に□書化する。
8. サポート期間は5年間と製品の使用期限のうち短い方とし、期間内はマニュファクチャラーは脆弱性に効果的に対処する。マニュファクチャラーは脆弱性開等に適切なポリシーや□続きを有する。
9. セキュリティアップデート公開から10年間、またはサポート期間のいずれか長い方の期間、セキュリティアップデートを利用可能とする。
10. 大幅な変更バージョンは付属書 I、パート II、ポイント (2) の必須要件に準拠すればよい。最新バージョンへは無料でアクセスでき、旧バージョンユーザーが環境調整コストなしで適用できること。
11. ユーザーが過去のバージョンおよびサポート外ソフトウェアの使用に伴うリスク情報にアクセスできるようにする。
12. 上市前にマニュファクチャラーは技術□書を作成する。対応する適合性評価□続きを□い、適合性が実証された場合はCEマーキングを貼付する。
13. 上市後10年間、技術□書と（該当する場合は）EU適合性証明書を市場監視当局が□由に使えるように保管する。
14. □連の製造の中で、適合性を維持するための□順が整備されていることを確認する。
15. 製品の個体識別のため型番、バッチ番号、シリアル番号などを付記する。
16. 製品にマニュファクチャラーの名前、商標、郵便住所、電子メールアドレスなどのデジタル連絡先、ウェブサイトなどを表示する。
17. 脆弱性報告ための単一の連絡先を附属書 II に記載されているユーザーへの情報および指示に記載する。連絡先はユーザーが通信手段を選択できるようにし、手段を自動化ツールに限定してはならない。
18. 附属書 II に定めるユーザーへの情報および説明書を紙または電子形式で添付する。情報および説明書は10年間とサポート期間の長い方の期間保持し、オンライン提供の場合はアクセス可能とする。
19. 購入時に、第8項のサポート期間の終了日へアクセスできるようにする。可能であれば、マニュファクチャラーはサポート期間の終了をユーザーに通知する。
20. EU適合性証明書か簡易EU適合宣言を提供する。簡易宣言の場合は完全なEU適合宣言へのURLを提供する。
21. サポート期間内に附属書II「セキュリティ特性要件」を遵守しない場合、直ちに必要な是正措置を講じ製品の撤回またはリコールを□う。
22. 市場監視当局からの要求に応じて製品の適合性を証明する情報・□書を提出する。
23. 操業を停□し義務を遵守できなくなる場合、操業停□前に市場監視当局やユーザに通知する。
24. 欧州委員会は実施法の中で、SBOMの形式と要素を指定することができる。
25. ADCO は製品のフリーソフトウェアおよびオープンソースソフトウェアへの依存度評価の実施を決定できる。市場監視当局は附属書I第II部ポイント(1)の SBOM 提供を要求できる。

設計前のリスクアセスメントの実施及び設計書への反映を文書化する必要がある。
製品寿命もしくは5年間は脆弱性処理要件を満たす必要がある。（ PSIRT相当の対応が必須）

CRA 第14条 マニュファクチャラーの報告義務

※赤字：OSSスチュワードの義務に関連がある条文

1. **悪用されている脆弱性を認識した場合は第　7項に従い CSIRT と ENISA に同時に通知する。**
2. 第1項の通知では以下を提出する。
   (a) 脆弱性を認識してから24時間以内に早期警告通知
   (b) 脆弱性を認識してから72時間以内に、製品の一般情報、悪用の性質、講じられた・またはユーザーが講じられる是正・緩和措置を含む脆弱性通知
   (c) 是正措置または緩和措置が利用可能になってから 14日以内に以下を含む最終報告書
      (i) 脆弱性の説明（その深刻度および影響を含む）
      (ii) 入手可能な場合、脆弱性を悪用した悪意のある行為者に関する情報
      (iii) 脆弱性修正のためのセキュリティアップデートまたはその他の是正措置に関する詳細
3. **製品のセキュリティに影響を与える重大なインシデントを認識した場合は第　7項に従い CSIRT と ENISA に同時に通知する**
4. 第3項の通知では以下を提出する。
   (a) インシデントを認識してから 24時間以内に早期警告通知。違法または悪意のある行為により比企侵された疑いがあるかを含む
   (b) インシデントを認識してから 72時間以内に、インシデントに関する一般情報と初期評価、講じられた・またはユーザーが講じられる是正・緩和措置を含むインシデント通知
5. 以下の場合インシデントは重大とみなす。
   (a) 機密性の高いまたは重要なデータや機能の可用性、真正性、完全性、または機密性を保護する能力に悪影響を及ぼす可能性がある
   (b) ユーザーのネットワークおよび情報システムにおいて悪意のあるコードの導入または実行につながる可能性がある
6. CSIRT は現在悪用されている脆弱性や重大なインシデントに関する中間レポートの提供を製造元に要求する場合がある。
7. 第1項と第3項の通知は、第 16条で規定する単一の報告プラットフォームを介して提出される。
8. **積極的に悪用されている脆弱性または重大なインシデントを認識した場合、これらについてユーザーに通知する。**
9. 本法案発効日から 12ヶ月以内に欧州委員会は第 61条に委任行為を採択する。
10. 欧州委員会は、通知された情報の種類、形式、□順を更に指定することができる。

自社製品に対するサイバーセキュリティ・インシデントへの報告・対応・連絡を行う組織が求められる
当該義務は法律施行前に販売を開始し、施行後も出荷を継続する製品にも課せられることに注意　(第69条 経過規程 3)

Article13 とOpen-source software Stewardの義務

- マニュファクチャラーは、第三者から調達したコンポーネントを統合する際に、当該コンポーネントが製品のサイバーセキュリティを損なわないようデューデリジェンスを実施しなければならない
  これには、商業活動の一環として市場に出されていないフリーおよびオープンソースソフトウェアのコンポーネントも含まれる（Article13(5)）
  OSSスチュワードが提供する OSSが製品に統合される場合、そのセキュリティ品質や脆弱性管理の体制が問われるため(Article24)、間接的にこの条文の対象

- マニュファクチャラーは、オープンソースコンポーネントを含むデジタル要素とともに製品に組み込まれたコンポーネントの脆弱性を特定した場合、そのコンポーネントのマニュファクチャラーまたは保守者に報告し、脆弱性に対処・是正しなければならない（ Article13(6)）
  OSSスチュワードは OSSの保守者として脆弱性報告の受け手となる可能性があり、報告を受けた後の対応責任が生じる

OSSスチュワードが直接的に製品を市場に出していなくても、その OSSが製品に組み込まれることで CRAの義務の一部を担う可能性がある

Article14 とOpen-source software Stewardの義務

- マニュファクチャラーは、積極的に悪用される脆弱性を認識した場合、 ENISAおよび指定されたCSIRTに対して、遅滞なく報告しなければならない（ Article14(1)）
  この義務はデジタル要素を含む製品の開発に関与している範囲で適用される（ Article24(3)）

- マニュファクチャラーは、製品のセキュリティに影響を及ぼす重大なインシデントを認識した場合、 ENISAおよび指定されたCSIRTに対して、遅滞なく報告しなければならない（ Article14(3)）
  この義務はセキュリティに影響を与える重大なインシデントが、その製品の開発のために OSSスチュワードが提供するネットワークおよび情報システムに影響を及ぼす限りにおいて適用される（ Article14(3)）

- マニュファクチャラーは、積極的に悪用される脆弱性や製品のセキュリティに影響を及ぼす重大なインシデントを認識した場合、影響を受けるユーザーに通知し必要に応じリスク緩和策を提供する必要がある
  この義務はセキュリティに影響を与える重大なインシデントが、その製品の開発のために OSSスチュワードが提供するネットワークおよび情報システムに影響を及ぼす限りにおいて適用される（ Article14(3)）

これらの条文の義務は、Article24（OSSスチュワードの義務）の 3項で定義された範囲で適用される

Open-source software Steward のCRA対応ガイド

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Open-source software StewardのCRA対応ガイド

1. セキュリティポリシーと開発体制の整備（第 24条）
   - セキュリティポリシーを文書化・公開
2. 脆弱性管理と報告体制の構築（第 13条・第24条）
   - 脆弱性報告窓口の設置
   - 脆弱性の評価・修正・公開のプロセス整備
   - ENISAや製品製造者からの報告に対応できる体制構築
3. SBOM（ソフトウェア部品表）の提供支援（第 13条）
   - OSSのバージョン、依存関係、ライセンス情報等の情報を機械可読形式で提供
4. セキュリティアップデートの提供（第 13条）
   - 既知の脆弱性に対するセキュリティアップデートの提供
   - 長期サポート（LTS）バージョンの提供の検討
5. 市場監視機関（MSA）との連携準備（第 24条）
   - 法的通知や問い合わせに対応する責任者を明確化
   - MSAの要請に応じて技術文書やセキュリティ情報を提出できる体制を整備
6. 技術文書と証跡の整備（第 13条）
   - セキュリティ設計、リスク評価、脆弱性対応履歴を記録

Open-source software Steward 最新動向

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Open-source software StewardのCRA対応ガイド

1. セキュリティポリシーと開発体制の整備（第 24条）
   - セキュリティポリシーを文書化・公開
2. 脆弱性管理と報告体制の構築（第 13条・第24条）
   - 脆弱性報告窓口の設置
   - 脆弱性の評価・修正・公開のプロセス整備
   - ENISAや製品製造者からの報告に対応できる体制構築
3. SBOM（ソフトウェア部品表）の提供支援（第 13条）
   - OSSのバージョン、依存関係、ライセンス情報等の情報を機械可読形式で提供
4. セキュリティアップデートの提供（第 13条）
   - 既知の脆弱性に対するセキュリティアップデートの提供
   - 長期サポート（LTS）バージョンの提供の検討
5. 市場監視機関（MSA）との連携準備（第 24条）
   - 法的通知や問い合わせに対応する責任者を明確化
   - MSAの要請に応じて技術文書やセキュリティ情報を提出できる体制を整備
6. 技術文書と証跡の整備（第 13条）
   - セキュリティ設計、リスク評価、脆弱性対応履歴を記録

Thank you



Legal Notice

Copyright © Open Source Security Foundation®, The Linux Foundation®, & their contributors. The Linux Foundation has registered trademarks and uses trademarks. All other trademarks are those of their respective owners.

Per the OpenSSF Charter, this presentation is released under the Creative Commons Attribution 4.0 International License (CC-BY-4.0), available at <https://creativecommons.org/licenses/by/4.0/>. You are free to:

- Share — copy and redistribute the material in any medium or format for any purpose, even commercially.
- Adapt — remix, transform, and build upon the material for any purpose, even commercially.

The licensor cannot revoke these freedoms as long as you follow the license terms:

- Attribution — You must give appropriate credit , provide a link to the license, and indicate if changes were made . You may do so in any reasonable manner, but not in any way that suggests the licensor endorses you or your use.
- No additional restrictions — You may not apply legal terms or technological measures that legally restrict others from doing anything the license permits.